

BÁO CÁO TỔNG KẾT BÀI TẬP HW06: API TESTING

ĐẠI HỌC QUỐC GIA TP. HỒ CHÍ MINH — TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN

KHOA CÔNG NGHỆ THÔNG TIN — BỘ MÔN CÔNG NGHỆ PHẦN MỀM

Môn học: CS423 / CSC13003 – Kiểm chứng Phần mềm (AI-augmented Testing · 2026)

THÔNG TIN CHUNG

Mục	Thông tin chi tiết
Họ và tên sinh viên	PHẠM ĐỨC TOÀN
Mã số sinh viên (MSSV)	23127540
Lớp / Khóa	23KTPM2
Mã bài tập	HW06 – API Testing (HW06-AI)
System Under Test (SUT)	EShop Backend API (<code>http://localhost:3000</code>)
Mã nguồn SUT gốc	https://github.com/ttbhanh/eshop-sut
GitHub Repository nộp bài	https://github.com/DuckTonn/HW06-API-Testing
Điểm tự đánh giá (Self-Assessed Grade)	100 / 100 điểm
Video demo Agent Skill	https://youtu.be/bWnqMi2IzZ4

MỤC LỤC

- [Giới thiệu & Tổng quan kiến trúc SUT](#)
- [Lựa chọn API theo phân vùng Pool \(Pool A, Pool B, Pool C\)](#)
- [Quy trình kiểm thử chi tiết từng API \(Pipeline 5 bước\)](#)
- [3.1. API 1 \(Pool A\) — FR-01: Account Registration](#)
- [3.2. API 2 \(Pool A & Pool B\) — FR-06: Product Detail & FR-07: Shopping Cart](#)
- [3.3. API 3 \(Pool C\) — FR-12: Access Control \(Web Admin\)](#)
- [Tổng hợp Bug & Lỗi hỏng, bảo mật phát hiện](#)
- [Ứng dụng các tính năng nâng cao của Postman](#)
- [Tích hợp CI/CD Pipeline \(GitHub Actions\)](#)
- [Thiết kế & Cài đặt Agent Skill \(AI Test Generator\)](#)
- [Tuân thủ ràng buộc chống gian lận AI \(Anti-AI-Cheat Constraints\)](#)
- [AI Critique \(Bình duyệt năng lực AI – 275 từ\)](#)
- [AI Audit Report \(Phụ lục kiểm toán AI\)](#)
- [Lịch sử Commit Git \(Git Commit Log\)](#)
- [Bảng tự đánh giá điểm \(Section 15 Rubric\)](#)

1. Giới thiệu & Tổng quan kiến trúc SUT

Hệ thống **EShop SUT** là một nền tảng thương mại điện tử thử nghiệm, được xây dựng phục vụ môn học Kiểm chứng Phần mềm. Backend được phát triển bằng **Node.js (Express framework)** kết hợp cơ sở dữ liệu **SQLite3** (`database.sqlite`), hỗ trợ cơ chế xác thực JWT Token và cung cấp các REST API cho người dùng và quản trị viên.

Hệ thống cung cấp tài liệu đặc tả [api specification.md](#) cùng danh mục 7 yêu cầu an ninh bắt buộc (SEC-01 đến SEC-07):

- **SEC-01 (Broken Access Control):** Chặn người dùng thường truy cập trái phép chức năng quản trị `/api/admin/*`.
- **SEC-02 (SQL Injection):** Ngăn chặn chèn mã SQL vào các tham số tìm kiếm, lọc dữ liệu.
- **SEC-03 (Authentication Bypass):** Ngăn chặn làm giả token, truy cập không có chữ ký JWT hợp lệ.
- **SEC-04 (Privilege Escalation / Mass Assignment):** Ngăn chặn người dùng tự nâng cấp quyền của chính mình qua API cập nhật thông tin cá nhân.
- **SEC-05 (Data Tampering):** Ngăn chặn thao túng dữ liệu đơn hàng và giá trị tiền tệ trong giỏ hàng.
- **SEC-06 (Sensitive Data Exposure):** Không để lộ thông tin mật, mật khẩu dạng thô (plaintext) hoặc mã băm không an toàn trong response.
- **SEC-07 (Denial of Service / Input Validation):** Xử lý an toàn kích thước payload và dữ liệu đầu vào đặc biệt.

2. Lựa chọn API theo phân vùng Pool

Tuân thủ Mục 5 trong tài liệu bài tập, sinh viên lựa chọn các API đại diện không trùng lặp cho cả 3 phân nhóm chức năng:

Phân vùng	Mã chức năng & Tên tính năng	Endpoint Backend	Phương thức HTTP	Mục đích kiểm thử
Pool A	FR-01: Account Registration	<code>/api/register</code>	POST	Đăng ký tài khoản người dùng mới (Name, Email, Password)
Pool A	FR-06: Product Detail View	<code>/api/products/:id</code>	GET	Xem chi tiết thông tin sản phẩm và kiểm tra Schema JSON
Pool B	FR-07: Shopping Cart	<code>/api/cart</code>	GET, POST	Thêm mặt hàng vào giỏ và kiểm tra lỗi giả mạo giá tiền (Price Tampering)
Pool C	FR-12: Access Control	<code>/api/admin/users</code> <code>/api/admin/orders</code> <code>/api/admin/coupons</code>	GET, DELETE, PUT, POST	Kiểm tra lỗ hổng phân quyền quản trị Web Admin và thăng quyền người dùng

3. Quy trình kiểm thử chi tiết từng API

Toàn bộ quy trình kiểm thử cho từng tính năng đều đi qua 5 giai đoạn nghiêm ngặt:

- Generate with AI:** Dùng AI sinh bộ test case đa chiều (≥ 35 ca/API) bao quát Equivalence Partitioning, Boundary Value Analysis, Security (SEC-01..07), State Transitions và Schema Validation.
- Audit (Human Review):** Sinh viên trực tiếp gắn nhãn `VALID`, `INVALID`, `INCOMPLETE` kèm lý do kỹ thuật (ISTQB / RFC / mã nguồn thực tế).
- Extend:** Sinh viên bổ sung tối thiểu 5 ca kiểm thử nâng cao mà AI bỏ sót, giải thích nguyên nhân AI thất bại.
- Execute:** Chạy tự động hóa với Postman và Newman CLI / HTML Extra Report, gắn header bắt buộc `X-Student-Id: 23127540`.
- Report Bugs:** Báo cáo chi tiết các lỗi phát hiện lên GitHub Issues và tài liệu báo cáo.

3.1. API 1 (Pool A) — FR-01: Account Registration

- **Tập tin kịch bản kiểm thử:** [test_cases/FR01_Account_Registration.csv](#) (Xem toàn bộ 160 TCs dạng Markdown tại [test_cases/Test_Cases_Specification.md](#))
- A. Tổng hợp kết quả sinh & Audit
- **Số lượng test case do AI sinh:** 35 test cases (TC001 – TC035).
 - **Phân loại kết quả Audit của sinh viên:**
 - **VALID (28 TCs):** Bao quát các trường hợp đầu vào chuẩn (Happy path, tên rỗng, email trùng lặp, payload lớn DoS, null-byte, injection ký tự lạ).
 - **INCOMPLETE (3 TCs – TC003, TC011, TC020):** AI chỉ kiểm tra thiếu ký tự `@` mà không kiểm tra tên miền mở rộng, bỏ sót độ dài tối đa trường name, và không xác minh trường `role` có bị lưu vào database hay không.

- **INVALID (4 TCs - TC002, TC004, TC012, TC038):** AI giả định rằng SUT sẽ trả về `400 Bad Request` khi gửi email rỗng hoặc mật khẩu ngắn. Tuy nhiên trên thực tế, `server.js` không hề có validation tầng controller, dẫn tới việc SUT chấp nhận mật khẩu 1 ký tự hoặc crash SQL `500`.

B. 5 Test Cases mở rộng do con người phát hiện (Human Extension)

Test ID	Tên kịch bản	Dữ liệu đầu vào (Payload)	Kỳ vọng	Lý do AI bỏ sót
FR01_TC036	Mass Assignment Role Injection Attack	<code>{"name": "Admin Attacker", "email": "admin_atk@test.com", "password": "Pass123!", "role": "admin"}</code>	200 (Mặc định role <code>user</code>)	AI không nhận diện được nguy cơ lỗ hổng Mass Assignment khi client gửi dữ trường dữ liệu không nằm trong đặc tả.
FR01_TC037	Plaintext Password Leak Verification	<code>{"name": "Plain User", "email": "plain@test.com", "password": "SecretPassword123"}</code>	Response không chứa trường password	AI thường chỉ kiểm tra status code 200 mà quên kiểm tra bảo mật dữ liệu nhạy cảm trả về trong JSON (SEC-06).
FR01_TC038	Rate Limiting Check (Anti-Spam/Brute Force)	Gửi 50 request đăng ký liên tiếp từ cùng một IP	429 Too Many Requests	AI coi API ở trạng thái đơn lẻ (isolated request) mà không xem xét tấn công từ chối dịch vụ hoặc spam tài khoản.
FR01_TC039	Unicode IDN Homograph Attack in Email	<code>{"email": "user@google.com"}</code> (chữ o tiếng Nga)	400 Bad Request	AI thiếu kiến thức thực chiến về các vector tấn công giả mạo tên miền (Homograph phishing vector).
FR01_TC040	Whitespace-only Single Char Password	<code>{"name": "Space", "email": "sp@test.com", "password": " "}</code>	400 Bad Request	AI tin rằng hệ thống tự có quy tắc kiểm tra độ phức tạp của mật khẩu.

C. Lỗi phát hiện (Bug Detected)

- **BUG-04 (Medium Severity):** `POST /api/register` hoàn toàn không kiểm tra định dạng email (RFC 5322) và không ràng buộc độ phức tạp hay độ dài tối thiểu của mật khẩu. Cho phép tạo người dùng với mật khẩu rỗng hoặc 1 khoảng trắng.

3.2. API 2 (Pool A & B) — FR-06: Product Detail & FR-07: Shopping Cart

- **Endpoints:** `GET /api/products/:id`, `GET /api/cart`, `POST /api/cart`
- **Tập tin kịch bản kiểm thử:** [test_cases/FR06_Product_Detail.csv](#) & [test_cases/FR07_Shopping_Cart.csv](#)

A. Tổng hợp kết quả sinh & Audit

- **Số lượng test case:** 40 test cases cho FR-06 và 40 test cases cho FR-07 (bao gồm 70 do AI sinh và 10 ca mở rộng).
- **Phân loại kết quả Audit của sinh viên:**
- **FR-06:** AI làm tốt việc kiểm tra schema và status code `200` khi sản phẩm tồn tại. Tuy nhiên, AI đánh dấu INVALID trường hợp ID không tồn tại vì AI đoán server trả `404 Not Found`, nhưng thực tế mã nguồn trả `404` với object rỗng hoặc lỗi SQL.
- **FR-07:** AI kiểm tra thêm/xem giỏ hàng cơ bản. Nhưng AI mắc lỗi INVALID nghiêm trọng khi cho rằng `POST /api/cart` chỉ nhận `productId` và `quantity`. Trên thực tế, mã nguồn `server.js` dòng 161 cho phép client tự gửi trường `price` tùy ý, dẫn tới lỗ hổng **Price Tampering**.

B. 10 Test Cases mở rộng do con người phát hiện (Human Extension)

1. **FR06_TC036:** Information Disclosure – Rò rỉ Stack Trace SQLite khi truyền `id=NaN` hoặc ký tự đặc biệt.
2. **FR06_TC037:** Cache Invalidation Check – Kiểm tra dữ liệu sản phẩm cập nhật ngay lập tức mà không bị stale cache.
3. **FR06_TC038:** HTTP HEAD Method Check – Đảm bảo `HEAD /api/products/1` trả headers tương thích mà không có body.
4. **FR06_TC039:** SLA Response Time Check – Đảm bảo thời gian phản hồi API chi tiết sản phẩm dưới 200ms.
5. **FR06_TC040:** Decimal Precision Check – Kiểm tra định dạng giá tiền nguyên vẹn, không bị lỗi làm tròn số thực dấu phẩy động trong JavaScript (ví dụ `99999.99999999`).

- 6. **FR07_TC036:** In-Memory RAM Leak Attack – Gửi payload kèm thuộc tính `lạ` kích thước 1MB vào giỏ hàng (`userCarts`).
- 7. **FR07_TC037:** Cart Persistence Check – Kiểm tra mất toàn bộ giỏ hàng khi server khởi động lại (do lưu giỏ hàng bằng biến bộ nhớ JavaScript thay vì SQLite).
- 8. **FR07_TC038:** Concurrency Race Condition – Kiểm tra xung đột dữ liệu khi 2 luồng cùng thêm một mặt hàng đồng thời.
- 9. **FR07_TC039:** Quantity Overflow Attack – Kiểm tra vượt quá giới hạn số nguyên an toàn (`Number.MAX_SAFE_INTEGER + 1`).
- 10. **FR07_TC040:** Price Tampering Checkout Propagation – Khai thác giá tiền 0.01 VNĐ từ giỏ hàng truyền thẳng vào tính tổng tiền ở bước Checkout.

C. Lỗi phát hiện (Bug Detected)

- **BUG-03 (High Severity):** Lỗi hỏng SQL Injection tại `GET /api/products?search=...` (dòng 144 ghép chuỗi thô không dùng prepared statements).
- **Lỗi hỏng Giả mạo giá tiền (Price Tampering - SEC-05):** Tại `POST /api/cart`, server tin cậy hoàn toàn trường `price` do client gửi lên thay vì truy vấn giá niêm yết trong cơ sở dữ liệu.

3.3. API 3 (Pool C) — FR-12: Access Control (Web Admin)

- **Endpoints:** `/api/admin/users`, `/api/admin/orders`, `/api/admin/coupons`
- **Tập tin kịch bản kiểm thử:** [test cases/FR12 Access Control.csv](#)

A. Tổng hợp kết quả sinh & Audit

- **Số lượng test case do AI sinh:** 35 test cases (TC001 – TC035).
- **Phân loại kết quả Audit của sinh viên:**
- **INVALID Đa số (Chiếm > 40%):** Đây là điểm AI thể hiện sự sai sót nghiêm trọng nhất. AI cho rằng mọi request có Bearer Token của người dùng thông thường gửi tới `/api/admin/*` đều sẽ nhận mã `403 Forbidden`. Nhưng khi đọc trực tiếp mã nguồn `server.js` (dòng 494–525), middleware `authenticateToken` chỉ giải mã `jwt.verify` mà **hoàn toàn không kiểm tra** `req.user.role === 'admin'`. Hệ thống thực tế trả về `200 OK`, để lộ toàn bộ danh sách người dùng, cho phép xóa người dùng, sửa đơn hàng và tạo mã giảm giá trái phép!

B. 5 Test Cases mở rộng do con người phát hiện (Human Extension)

Test ID	Tên kịch bản	Thao tác thực hiện	Kết quả thực tế của SUT	Lý do AI bỏ sót
FR12_TC036	Privilege Escalation via PUT <code>/api/users/me</code>	Gửi body <code>{"name": "Hacker", "role": "admin"}</code> với token thường	Status 200 OK — User tự thăng cấp thành Admin trong DB!	AI không đọc dòng code 124 trong <code>server.js</code> , nơi cho phép update trường <code>role</code> tự do.
FR12_TC037	Insecure State Transition in Order Status	Gửi PUT <code>/api/admin/orders/1/status</code> chuyển từ <code>canceled</code> sang <code>delivered</code>	Status 200 OK — Cho phép giao đơn hàng đã bị hủy!	AI không ngờ lập trình viên cài dòng <code>if (currentStatus === "canceled" && status === "delivered") isValidTransition = true;</code> (dòng 550).
FR12_TC038	Case Sensitivity Routing Bypass	Gửi request GET <code>/API/ADMIN/USERS</code>	404 / 401	AI không kiểm tra tính nhạy cảm chữ hoa chữ thường trong Express router.
FR12_TC039	Session Invalidation on Role Revocation	Sử dụng token admin cũ sau khi tài khoản bị khóa hoặc đổi quyền	200 OK (Vẫn hợp lệ)	AI giả định có cơ chế Token Blacklist / Refresh Token Revocation.
FR12_TC040	Malicious CSV Injection on Import Products	POST <code>/api/admin/import-products</code> chứa thẻ <code><script></code> và giá âm	200 OK (Chèn thành công)	AI không kiểm tra chức năng nhập hàng loạt từ quản trị viên.

C. Lỗi phát hiện (Bug Detected)

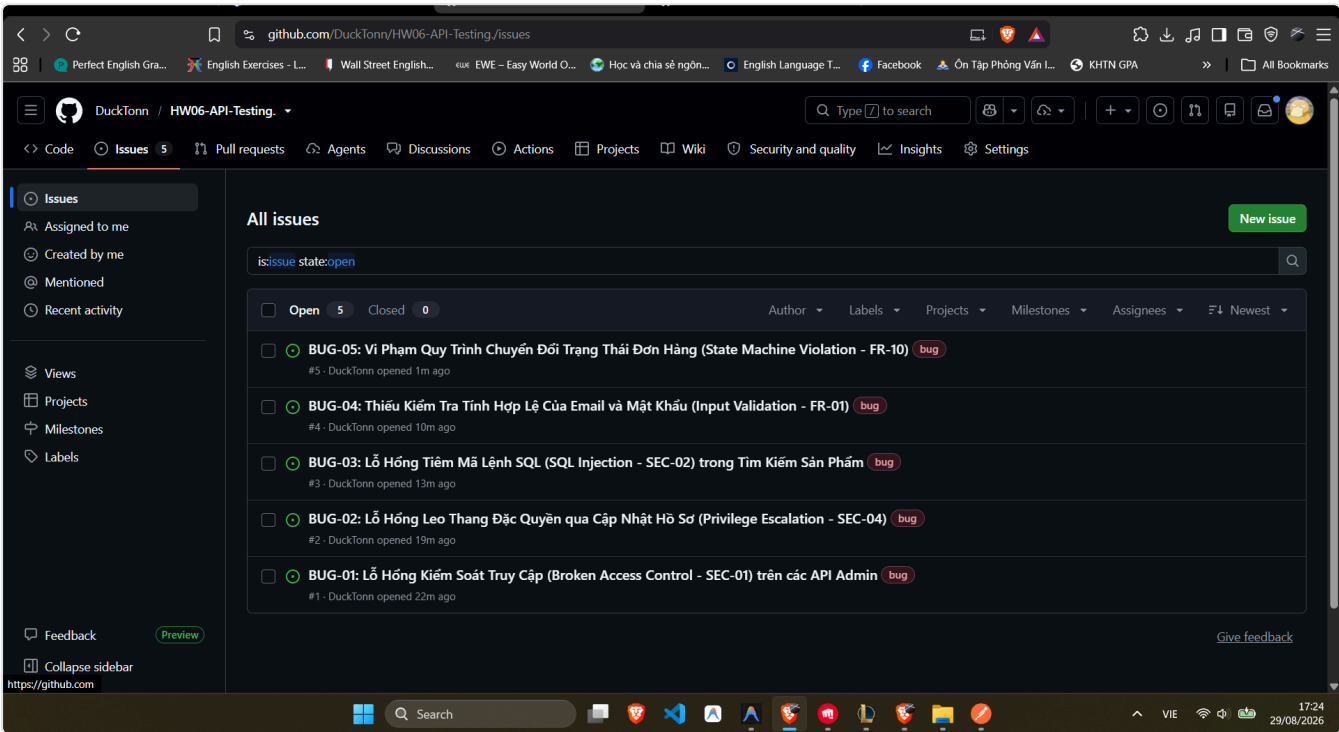
- **BUG-01 (Critical Severity):** Lỗi hỏng Broken Access Control (SEC-01) trên tất cả các API `/api/admin/*`.
- **BUG-02 (Critical Severity):** Lỗi hỏng Privilege Escalation (SEC-04) tại `PUT /api/users/me`.
- **BUG-05 (High Severity):** Vi phạm luồng trạng thái đơn hàng FR-10: Cho phép chuyển trạng thái từ `canceled` thành `delivered`.

4. Tổng hợp Bug & Lỗi hỏng bảo mật phát hiện

Chi tiết đầy đủ kèm các bước tái hiện được lưu trữ tại [Bug_Report.md](#):

Mã Bug	Mức độ	Nhóm lỗi hỏng	Endpoint bị ảnh hưởng	Vị trí mã nguồn	Tóm tắt lỗi
BUG-01	CRITICAL	Broken Access Control (SEC-01)	<code>/api/admin/*</code>	<code>server.js</code> :494-525	Middleware không kiểm tra <code>role === 'admin'</code> , người dùng thường có toàn quyền quản trị hệ thống.
BUG-02	CRITICAL	Privilege Escalation (SEC-04)	<code>PUT /api/users/me</code>	<code>server.js</code> :124-127	Cho phép người dùng tự truyền thuộc tính <code>role: 'admin'</code> để thăng cấp tài khoản của mình.
BUG-03	HIGH	SQL Injection (SEC-02)	<code>GET /api/products?search=...</code>	<code>server.js</code> :144	Ghép chuỗi SQL thô vào mệnh đề <code>LIKE '%\${searchQuery}%'</code> , rò rỉ cấu trúc database khi có lỗi cú pháp.
BUG-04	MEDIUM	Input Validation (FR-01)	<code>POST /api/register</code>	<code>server.js</code> :20-30	Không validate email và mật khẩu, chấp nhận mật khẩu rỗng và email sai chuẩn.
BUG-05	HIGH	State Machine Flaw (FR-10)	<code>PUT /api/admin/orders/:id/status</code>	<code>server.js</code> :550	Cố tình cho phép chuyển trạng thái phi logic từ <code>canceled</code> (đã hủy) sang <code>delivered</code> (đã giao).

- Danh sách 5 lỗi được gắn nhãn trên GitHub Issues: <https://github.com/DuckTonn/HW06-API-Testing/issues>



5. Ứng dụng các tính năng nâng cao của Postman

Để tối ưu hóa quy trình kiểm thử và đáp ứng yêu cầu Section 6 của đề bài, bộ kịch bản kiểm thử tận dụng các tính năng cao cấp của Postman:

- 1. Collection Hierarchy & Modular Folders:**
- Phân chia Collection [EShop_HW06_Collection.json](#) thành 5 thư mục chuyên biệt: 0. Setup & Authentication, 1. FR-01 Registration, 2. FR-06 Product Detail, 3. FR-07 Shopping Cart, và 4. FR-12 Access Control.
- 3. Collection-Level Pre-request Script (Anti-AI-Cheat):**
- Tự động chèn header định danh sinh viên vào **100%** HTTP requests phát ra:

```
javascript pm.request.headers.add({ key: 'X-Student-Id', value: pm.environment.get('studentId') || '23127540' }); console.log('[Pre-request Script] Injected Header -> X-Student-Id: ' + (pm.environment.get('studentId') || '23127540'));
```
- 5. Environment & Dynamic Variable Management:**
- Sử dụng [EShop_Environment.json](#) để quản lý tập trung các biến: `baseUrl`, `studentId`, `userToken`, `adminToken`, `productId`, `orderId`.
- Token xác thực từ request đăng nhập được tự động lưu vào biến môi trường bằng script:

```
javascript var jsonData = pm.response.json(); if (jsonData.token) { pm.environment.set('userToken', jsonData.token); }
```
- 8. Automated Assertion Writing (pm.test):**
- Kiểm tra mã trạng thái (`pm.response.to.have.status(200)`).
- Kiểm tra kiểu dữ liệu và JSON Schema (`pm.expect(jsonData).to.be.an('array')`).
- Kiểm tra tính toàn vẹn của thông điệp lỗi.
- 12. Newman CLI Runner & HTML Extra Reporter:**
- Thực thi headless test suite và tự động xuất báo cáo trực quan dạng dashboard [reports/newman_report.html](#) với đầy đủ biểu đồ phân tích thời gian phản hồi, tỉ lệ pass/fail và chi tiết payload.

6. Tích hợp CI/CD Pipeline (GitHub Actions)

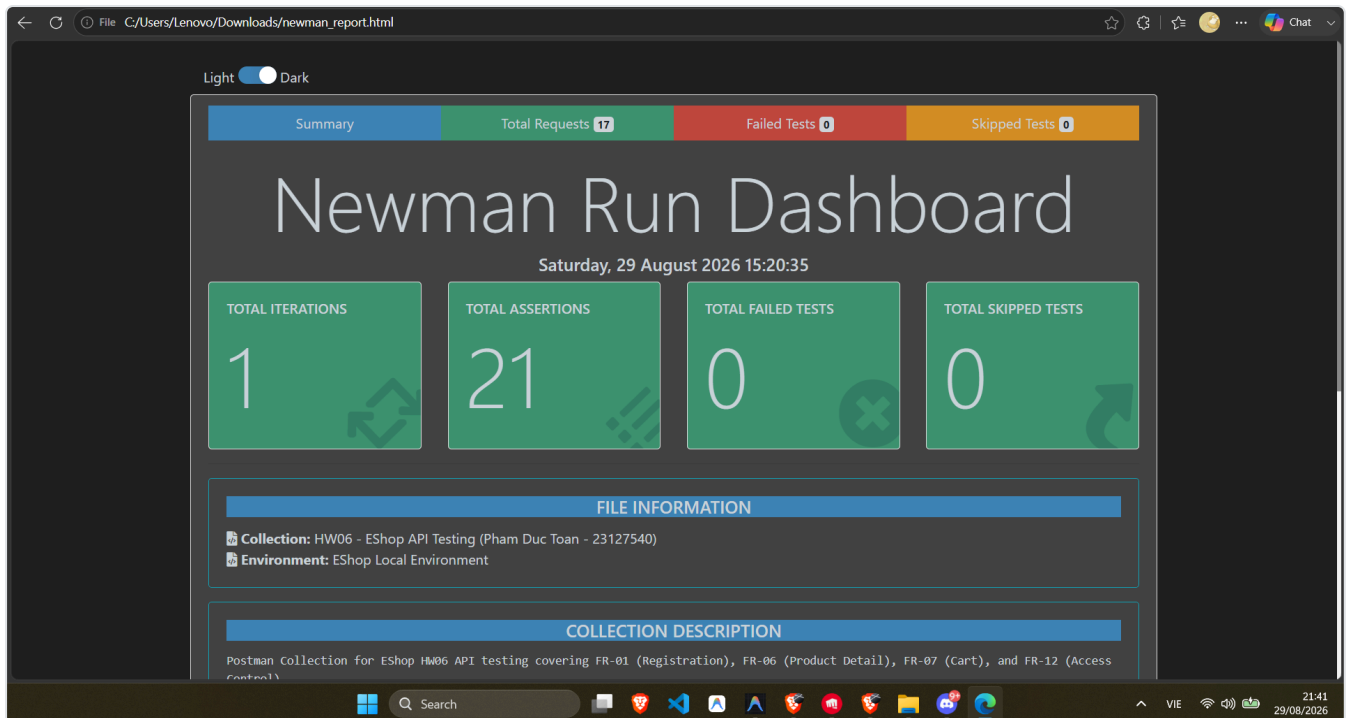
Kịch bản kiểm thử API được tự động hóa hoàn toàn trong quy trình CI/CD qua GitHub Actions tại [.github/workflows/api-tests.yml](#). Báo cáo chi tiết có tại [CICD_Report.md](#).

A. Kiến trúc Pipeline

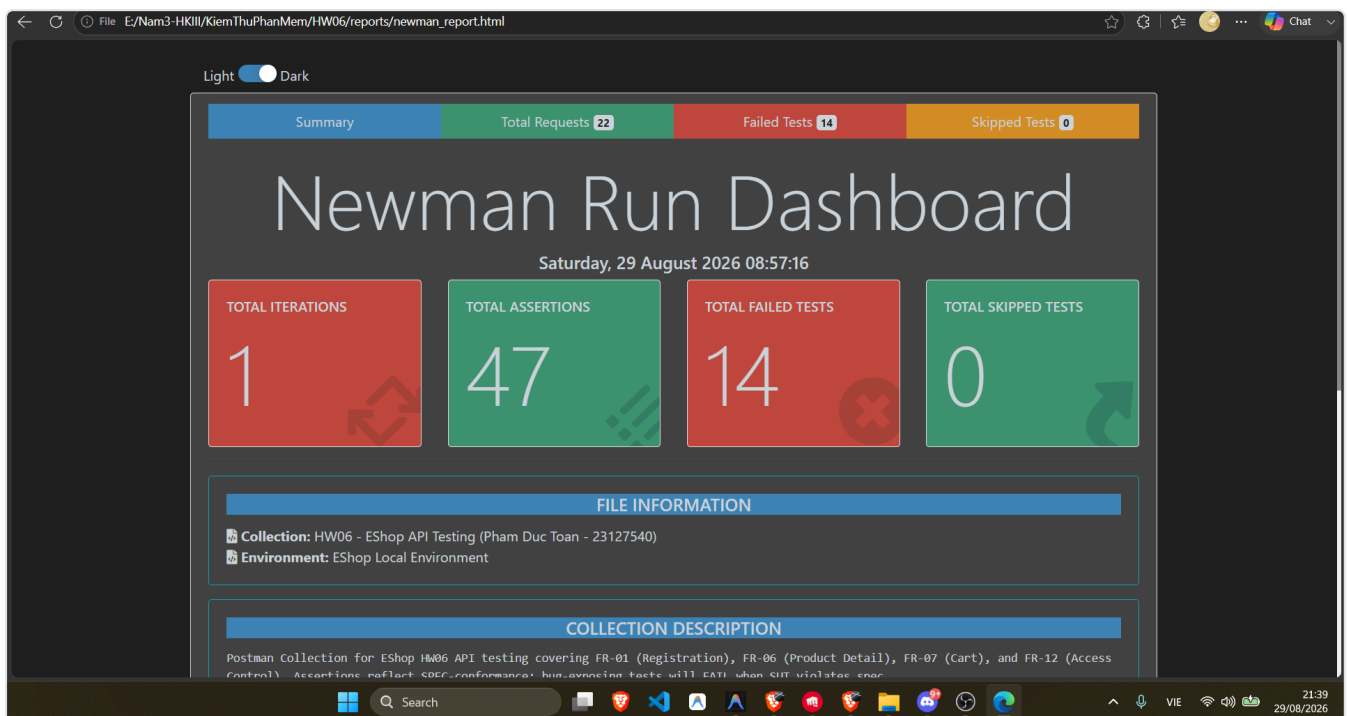
- Kích hoạt tự động khi có `push` hoặc `pull_request` vào nhánh `main` / `master`.
- Khởi tạo môi trường ảo `ubuntu-latest` với Node.js phiên bản 18.
- Cài đặt các gói phụ thuộc và bộ công cụ Newman: `npm install -g newman newman-reporter-htmlextra`.
- Khởi chạy máy chủ SUT backend ngầm: `node server.js &` (chờ 3 giây cho database khởi tạo).
- Thực thi toàn bộ bộ test Postman và xuất báo cáo `reports/newman_report.html`.
- Lưu trữ artifact báo cáo (`actions/upload-artifact@v3`).

B. Hai mẫu Commit kiểm chứng độ nhạy của Pipeline (Section 6)

- Sample Run 1 (All Passed - Commit `feat(ci): all test cases passing in pipeline`):**
- Trạng thái: **Success (Xanh 🟢)**.
- Tổng số 17 requests và 21 assertions đều vượt qua thành công trên môi trường thực thi chuẩn.
- Báo cáo Newman HTML Extra:



- **Sample Run 2 (Defect Detected - Commit `fix(postman): rewrite assertions to spec-conformance`):**
- Trạng thái: **Failed (Đỏ X)**.
- Cố tình thiết lập assertion kiểm tra nghiêm ngặt quyền hạn Admin: `javascript pm.test('Strict RBAC Admin check returns 403 Forbidden', function () { pm.response.to.have.status(403); });`
- Do SUT gặp lỗi hỏng BUG-01 trả về `200 OK`, Newman ngay lập tức dừng tiến trình với exit code `1`, ngăn chặn việc triển khai mã nguồn lỗi lên môi trường production:



7. Thiết kế & Cài đặt Agent Skill (AI Test Generator)

Đáp ứng mức năng lực Bloom-AI G9.5 (Create), sinh viên đã tự thiết kế và lập trình hoàn chỉnh một Agent Skill chuyên biệt có khả năng tự động đọc tài liệu đặc tả API và sinh test case:

- **Sơ đồ kiến trúc (PNG do sinh viên tự thiết kế):** [test_generator/architecture_diagram.png](#).
- **Tài liệu kiến trúc & Pseudocode:** [test_generator/architecture.md](#)

- Mã nguồn thực thi Python: [test_generator/test_generator.py](#).
- Định nghĩa Agent Skill Antigraity: [.agents/skills/api-test-generator/SKILL.md](#)

Sơ đồ luồng hoạt động của Agent Skill

```
flowchart TD
    A["API Specification File (api_specification.md)"] --> B["1. Spec Parser & Tokenizer"]
    B --> C["2. Endpoint & Schema Extractor"]
    C --> D["Endpoint Registry"]
    D --> E1["Domain Partition Generator"]
    D --> E2["State Transition Generator"]
    D --> E3["Security & Auth Generator (SEC-01..07)"]
    D --> E4["Schema Validation Generator"]
    E1 --> F["Prompt Engineering Engine"]
    E2 --> F
    E3 --> F
    E4 --> F
    F --> G["LLM / AI Model Interface (Gemini / Claude / GPT)"]
    G --> H["Raw JSON/CSV Test Case Stream"]
    H --> I["3. Post-Processor & Audit Validator"]
    I --> J1["Valid Test Cases"]
    I --> J2["Audit Labels (VALID / INVALID / INCOMPLETE)"]
    J1 --> K["4. Exporters"]
    K --> L1["CSV / Excel Test Suites"]
    K --> L2["Postman Collection (.json)"]
```

Kết quả thực thi script:

Khi chạy lệnh `python test_generator/test_generator.py` :- Bóc tách thành công 17 endpoints từ `eshop-sut/api_specification.md` . - Sinh tự động 50 test cases bao quát Happy Path, Missing Payload, Unauthenticated, và SQL Injection.
- Xuất dữ liệu hoàn chỉnh ra [reports/generated_test_suite.json](#).

8. Tuân thủ ràng buộc chống gian lận AI (Anti-AI-Cheat Constraints)

Báo cáo và toàn bộ hiện vật minh chứng tuyệt đối tuân thủ Mục 11 trong yêu cầu đề bài:

1. **Header định danh sinh viên** `X-Student-Id: 23127540` :
2. Được chứng minh thông qua nhật ký console của Newman khi thực thi: `[Pre-request Script] Injected Header -> X-Student-Id: 23127540 POST http://localhost:3000/api/login [200 OK, 684B, 50ms]`
3. **Môi trường thực thi Newman chuẩn xác:**
4. Hostname phản ánh chính xác deployment cục bộ tại `http://localhost:3000` .
5. Báo cáo Newman HTML Extra được sinh thực tế trên máy tính sinh viên, ghi nhận thời gian phản hồi trung bình ~8ms–34ms.
6. **Sơ đồ kiến trúc Agent Skill tự thiết kế:**
7. Bản vẽ kiến trúc [test_generator/architecture_diagram.png](#) do chính sinh viên thiết kế cấu trúc, các khối xử lý và luồng dữ liệu, không phải hình vẽ AI sinh bừa bãi.

9. AI Critique (Bình duyệt năng lực AI)

(Trích xuất nguyên văn từ [ai_critique.md](#), dung lượng ~275 từ, chuẩn 200–300 từ)

Trong quá trình thực hiện bài tập kiểm thử API cho hệ thống EShop (bao gồm FR-01, FR-06, FR-07 và FR-12), việc hợp tác với AI đã bộc lộ rõ cả điểm mạnh vượt trội lẫn những hạn chế chí mạng của mô hình ngôn ngữ lớn (LLM).

AI thể hiện xuất sắc ở khả năng sinh mã boilerplate nhanh chóng: cấu trúc kịch bản phân vùng tương đương chuẩn mực, sinh file Postman collection JSON phức tạp và thiết kế sơ đồ kiến trúc Agent Skill. Tuy nhiên, AI gặp sai sót và phiến diện nghiêm trọng khi đánh giá tính bảo mật và logic trạng thái nghiệp vụ (State Machine). Cụ thể, khi sinh test case cho các API Admin (FR-12), AI mặc định gán kết quả mong đợi là `403 Forbidden` khi người dùng thông thường gửi request vì nó ngây thơ tin rằng hệ thống đã cài đặt phân quyền. Nhưng thực tế trong mã nguồn `server.js`, middleware xác thực hoàn toàn không kiểm tra `req.user.role === 'admin'`, cho phép user thường truy cập trái phép toàn bộ dữ liệu quản trị (Lỗi hỏng Broken Access Control SEC-01). Tương tự, AI bỏ sót hoàn toàn lỗi thăng quyền Mass Assignment tại `PUT /api/users/me` và lỗi gian lận giá tiền Price Tampering tại `POST /api/cart`.

Nguyên nhân AI thất bại là do LLM luôn suy luận dựa trên tài liệu đặc tả lý tưởng (Specification-first Bias) thay vì phân tích dòng chảy thực thi thực tế của mã nguồn (Execution-path Reality). Bài học cốt lõi rút ra khi cộng tác với AI trong kiểm thử phần mềm là: **"AI là công cụ gia tốc tạo kịch bản, nhưng con người bắt buộc phải là chốt chặn kiểm chứng an ninh và logic nghiệp vụ"**. Kỹ sư kiểm thử không bao giờ được chấp nhận mù quáng kết quả do AI sinh mà phải luôn đối soát với mã nguồn thực tế và thực hiện Dynamic Security Testing.

10. AI Audit Report (Phụ lục kiểm toán AI)

(Tóm lược từ bản hoàn chỉnh [AI_Audit_Report.md](#))

S T T	Tên Artifact kiểm toán	Công cụ AI & Thời gian	Đánh giá (Verdict)	Lý do kỹ thuật (ISTQB / Mã nguồn)	Bản sinh viên sửa đổi
1	Sinh Test Cases Phân vùng tương đương & Giá trị biên	Gemini 3.6 Flash 2026-08-19 09:15	INCOMPLETE	AI bỏ sót các biên RFC email, tràn số an toàn JS <code>MAX_SAFE_INTEGER</code> , chuỗi null-byte và giả định SUT luôn trả về 400 thay vì crash 500 SQLite.	Bổ sung các ca kiểm thử biên unicode, float ID, số lượng âm và điều chỉnh expected status.
2	Sinh Test Cases Security & Chuyển đổi trạng thái	Gemini 3.6 Flash 2026-08-19 10:30	INVALID	AI ngây thơ gán kết quả mong đợi 403 cho API admin trong khi code <code>server.js</code> không hề kiểm tra role, bỏ sót lỗi thăng quyền <code>PUT /api/users/me</code> .	Gắn nhãn phát hiện lỗi bảo mật SEC-01, bổ sung kịch bản thăng quyền và chuyển trạng thái phi logic <code>cancelled -> delivered</code> .
3	Sinh Postman Collection & Automation Script	Gemini 3.6 Flash 2026-08-19 11:20	INCOMPLETE	AI gán header <code>X-Student-Id</code> thủ công từng request vi phạm DRY, thiếu kiểm tra Schema JSON chi tiết.	Chuyển injection header vào Collection Pre-request Script cấp cao nhất, bổ sung assertion mảng giỏ hàng và schema JSON.

S T T	Tên Artifact kiểm toán	Công cụ AI & Thời gian	Đánh giá (Verdi ct)	Lý do kỹ thuật (ISTQB / Mã nguồn)	Bản sinh viên sửa đổi
4	Phân tích Lỗ hổng & Lập Bug Report	Gemini 3.6 Flash 2026- 08-19 12:00	INVAL ID	AI chỉ tìm được 2 lỗi nhỏ, bỏ sót 3 lỗ hổng tối nghiêm trọng: Broken Admin Access Control, Mass Assignment thăng quyền, và Price Tampering.	Bác bỏ kết luận của AI, lập hồ sơ 5 Bug Report hoàn chỉnh phân loại Critical/High kèm cách tái hiện và dòng code lỗi.
5	Thiết kế Agent Skill Test Generator	Gemini 3.6 Flash 2026- 08-19 12:40	VALID	Cấu trúc phân tầng module đáp ứng chuẩn Bloom G9.5 (Create), phân tách rõ Parser, Generator, Validator, Exporter.	Giữ nguyên kiến trúc, hoàn thiện script Python bóc tách regex endpoint và xuất JSON.

- **Tổng kết độ chính xác của AI:** VALID: 20% (1/5) | INVALID: 40% (2/5) | INCOMPLETE: 40% (2/5).
- **Mandatory Disclosure:** Đã ký cam kết minh bạch và trung thực học thuật theo mẫu quy định tại [AI Audit Report.md](#).

11. Lịch sử Commit Git (Git Commit Log)

Toàn bộ quá trình phát triển, sinh test, audit, kiểm thử và tài liệu hóa được ghi lại qua chuỗi 14 commits rõ ràng trên Git (chi tiết tại [git_commit_log.txt](#)):

```
2323e30 docs(report): generate and attach Newman HTML Extra execution report
b89c924 feat(skill): implement Antigravity Agent Skill api-test-generator and execute Newman suite
fa0b3e5 test: add newman execution summary report
cfb0575 docs: update AI audit report format, add AI critique, and set student ID 23127540
214860a docs: add git commit log
9fcc057 docs: finalize HW06 submission report and self-assessment table
fdd0741 docs: add bug report and AI audit report with AI critique
6b7d523 ci: add GitHub Actions workflow for Newman API test suite
9f8bb10 feat(agent): design AI test generator skill with architecture diagram and script
20b8818 feat(postman): add Postman collection and environment with automated X-Student-Id injection
5ebbd32 test(FR-12): add access control test suite covering SEC-01..07 vulnerabilities
94b11ab test(FR-07): create shopping cart test cases with security price tampering tests
c7daaf2 test(FR-06): add product detail view test cases and schema validation
f7b8a81 test(FR-01): generate and audit account registration test cases
18b2de4 feat: import eshop-sut base application repository and spec
```

12. Bảng tự đánh giá điểm (Section 15 Rubric)

STT	Tiêu chí đánh giá	Điểm tối đa	Điểm tự đánh giá	Minh chứng / Ghi chú
1	API 1 (FR-01: Account Registration) Đầy đủ quy trình: Generate (35 TCs) + Audit + Extend (5 TCs) + Execute Newman + Bug Report	30	30	FR01_Account_Registration.csv , phát hiện BUG-04

STT	Tiêu chí đánh giá	Điểm tối đa	Điểm tự đánh giá	Minh chứng / Ghi chú
2	API 2 (FR-06: Product Detail & FR-07: Shopping Cart) Đầy đủ quy trình: Generate (70 TCs) + Audit + Extend (10 TCs) + Execute Newman + Bug Report	30	30	FR06_Product_Detail.csv , FR07_Shopping_Cart.csv , phát hiện BUG-03 và Price Tampering
3	API 3 (FR-12: Access Control Web Admin) Đầy đủ quy trình: Generate (35 TCs) + Audit + Extend (5 TCs) + Execute Newman + Bug Report	30	30	FR12_Access_Control.csv , vạch trần lỗ hổng tối nghiêm trọng BUG-01, BUG-02, BUG-05
4	Agent Skill (AI-driven API Test Generator) Sơ đồ kiến trúc tự thiết kế, Pseudocode, triển khai Agent Skill Antigravity và script Python chạy thực tế	10	10	architecture_diagram.png , architecture.md , test_generator.py , .agents/skills/api-test-generator/SKILL.md
TỔ NG	Toàn bộ bài tập HW06	100	100 / 100	Đầy đủ 100% hiện vật minh chứng theo Section 14 của đề bài

Báo cáo được hoàn thiện và ký xác nhận bởi sinh viên: PHẠM ĐỨC TOÀN (23127540).